New Zealand & Philippines Data Privacy

Laws & Regulations

Neeraj Patel

New Zealand’s Privacy Act 2020

- Enforceable from the 1st of December 2020
- Purpose: “Provide a framework for protecting an individual’s right to privacy and access to personal information, while also recognising other rights and interests”

13 Information Privacy Principles:

- IPP 1: Purpose of collection of personal information
- IPP 2: Source of personal information
- IPP 3: Collection of information from subject
- IPP 4: Manner of collection of personal information
- IPP 5: Storage and security of personal information
- IPP 6: Access to personal information
- IPP 7: Correction of personal information
- IPP 8: Accuracy, etc, of personal information to be checked before use or disclosure
- IPP 9: Agency not to keep personal information for longer than necessary
- IPP 10: Limits on use of personal information
- IPP 11: Limits on disclosure of personal information
- IPP 12: Disclosure of personal information outside New Zealand
- IPP 13: Unique identifiers

Relevant Principles:

- IPP 5: Storage and security of personal information
  - Organisations must ensure there are safeguards in place that are reasonable in the circumstances to prevent loss, misuse or disclosure of personal information.

- IPP 8: Accuracy, etc, of personal information to be checked before use or disclosure
  - Organisation must check before using or disclosing personal information that it is accurate, up to date, complete, relevant and not misleading.
  - For data Processing

- IPP 12: Disclosure of personal information outside New Zealand
  - Rules around sending personal information to organisations or people outside New Zealand

Philippines' Republic Act 10173

- Short Title: Data Privacy Act of 2012

- Enforceable from the 8th of September 2012

- Declaration of Policy: "It is the policy of the State to protect the fundamental human right of privacy, of communication while ensuring free flow of information to promote innovation and growth… Ensures that personal information and communications systems in the government and in the private sector are secured and protected."

9 Chapters of The Republic Act 10173

- Chapter 1: General Provisions
- Chapter 2: The National Privacy Commission
- Chapter 3: Processing of Personal Information
- Chapter 4: Rights of the Data Subject
- Chapter 5: Security of Personal Information
- Chapter 6 Accountability of Transfer of Personal Information
- Chapter 7: Security of Sensitive Personal Information in Government
- Chapter 8: Penalties
- Chapter 9: Miscellaneous Provisions

Relevant Chapters:

- Chapter 3: Processing of Personal Information
  - The processing of personal information shall be allowed, subject to compliance with the requirements of this Act and other laws allowing disclosure of information to the public and adherence to the principles of transparency, legitimate purpose and proportionality

- Chapter 5: Security of Personal Information
  - The personal information controller must implement reasonable and appropriate organizational, physical and technical measures intended for the protection of personal information against any accidental or unlawful destruction, alteration and disclosure, as well as against any other unlawful processing

- Chapter 6 Accountability of Transfer of Personal Information
  - Each personal information controller is responsible for personal information under its control or custody, including information that have been transferred to a third party for processing, whether domestically or internationally, subject to cross-border arrangement and cooperation

Considerations from a New Zealand context

Louis Isbister

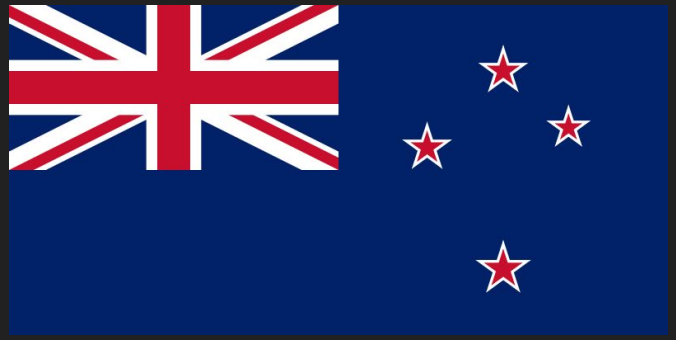
New Zealand Privacy Act of 2020 and Philippines Data Privacy Act of 2012

Similarities between New Zealand and Philippines data legislations:

1) Section 12 and 21 of the PDPA and IPP 12 - both require the recipient country to have equivalent data protection laws, or suitable safeguard.

2) Sections 16-18 of the PDPA and IPP's 6 and 7 - state that data subjects can request access to, correction of, and deletion of their data.

3) Section 22 of the PDPA and IPP 5 - require cloud providers to implement robust security measures, making the standards fairly comparable.



Data Breach Notification: Philippines & New Zealand

Key Consideration for NZ Organizations

- Prompt notification of data breaches in the Philippines.

Philippines Data Privacy Act (PDPA)

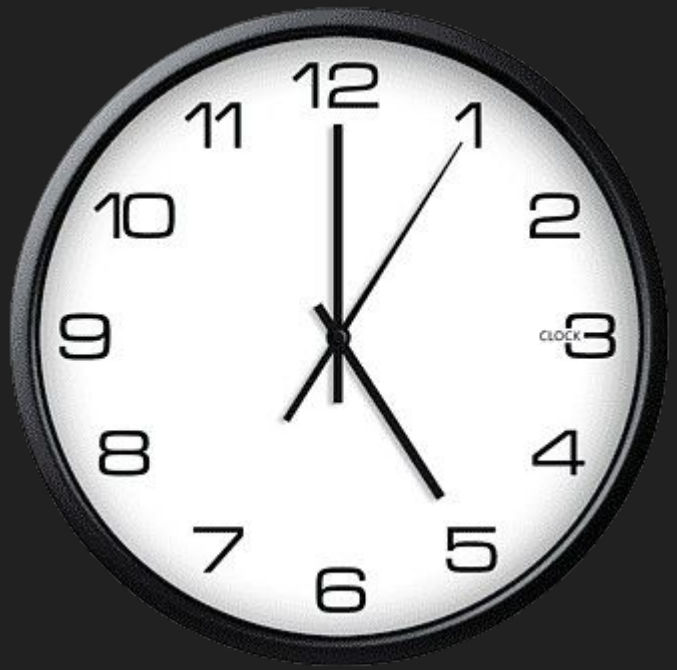
- Section 38: Mandatory notification to National Privacy Commission and individuals within 72 hours.

New Zealand's Privacy Act

- Notification to Office of the Privacy Commissioner and affected individuals if harm is possible.

Ensuring Transparency and Rapid Response

- Strict regulations in both countries help ensure NZ entities are promptly notified.



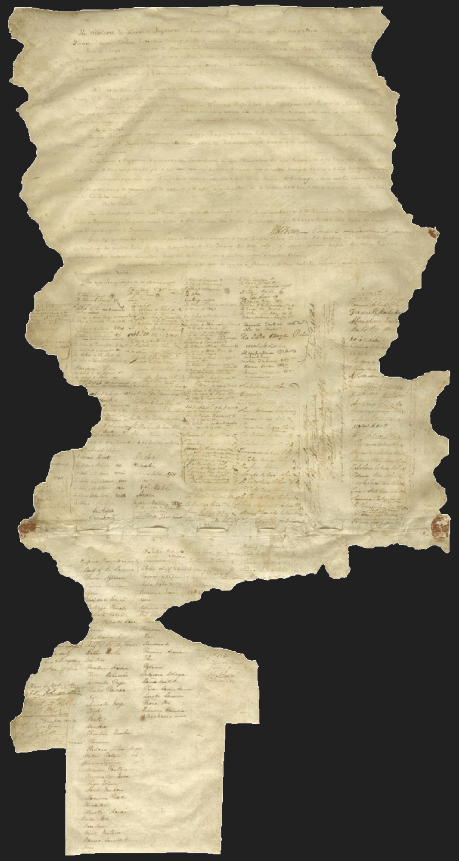
Treaty of Waitangi and Māori Data Sovereignty

Treaty Obligations
- Organizations must respect Māori rights and interests.

Māori Data Sovereignty
- Cultural sensitivity in handling data about iwi or Māori individuals.
- Preference for data to remain within New Zealand.

Ethical Concerns
- Lack of consultation on offshoring Māori data may breach sovereignty.

Action for Our Organization
- Investigate offshore cloud providers to ensure appropriate handling of Māori data, respecting Treaty obligations.
- Sensitive Māori data could be kept in New Zealand, while less sensitive data is outsourced, balancing cost and sovereignty.



Local and International Standards and Frameworks

Harry Ireland

Frameworks and Standards

Local:

- New Zealand Information Security Manual (NZISM)

International:

- General Data Protection Regulation (GDPR)
- National Institute of Standards and Technology (NIST) Security Framework
- ISO/IEC 27001, 27017, and 27018

New Zealand Information Security Manual (NZISM)

- Guidlines to help organisations protect sensitive personal data.
- Applies to do the government and private sectors.
- Includes: identity and access, incident, and vulnerability management.
- We need to ensure our Philippines based cloud provider complies with the NZISM.

Te Tira Tiaki
Government Communications Security Bureau

General Data Protection Regulation (GDPR)

Regulation of the European Union

Consistent with the PDPA:

- Article 5 - Collection
- Article 32 - Protection

Not consistent with the PDPA:

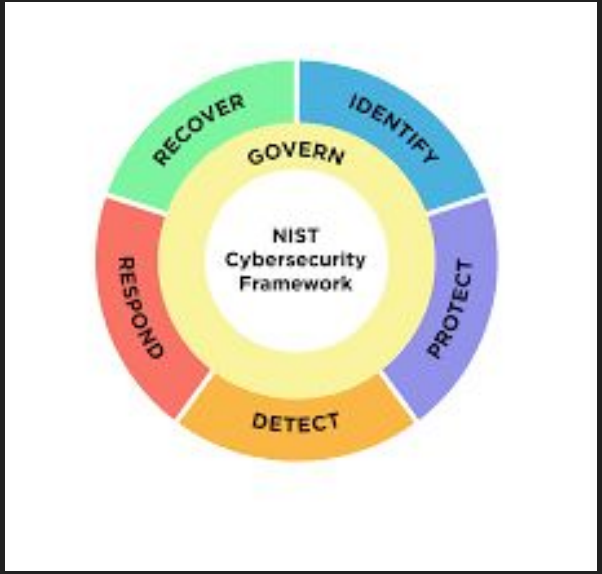
- Article 45 - Transfer

NIST Cybersecurity Framework

- Published by the National Institute of Standards and Technology (NIST).

- Governs these functions:
  - Identify
  - Protect
  - Detect
  - Respond
  - Recover

- Developed in the United States and free to use.



ISO/IEC 27001

- Published by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC).

- A certification that helps cloud providers implement, monitor, and maintain their information security management systems (ISMS).

- Requires a third party audit to achieve or retain.

ISO/IEC 27017 & 27018

ISO/IEC 27017:

- Includes implementation guidance and additional controls specific to cloud services.

ISO/IEC 27018:

- Focuses on personally identifiable information (PII).
- Provides guidance on protecting PII in cloud storage.

Cloud Providers with ISO/IEC 27001, 27017, and 27018

Passing it on to Ricky…

Ethical Considerations of Moving Data Offshore

Ricky Fong

Background

Why Offshoring?

- Cost reduction and managing higher transaction volumes.
- Philippines offers operational advantages, but data privacy and customer trust must be maintained.

Key Focus:

- How to **uphold data privacy** and **protect customer trust** when offshoring data to the Philippines.

Ethical Concern 1: Data Privacy and Protection Differences

Data Privacy Laws:

- **New Zealand Privacy Act 2020**:
  - Comprehensive protections for personal information.
  - Key principles: **purpose limitation**, **data minimization**, and **individual rights** to access and correct data.
- **Philippines Data Privacy Act of 2012**:
  - Protects personal information in both government and private sectors.
  - **Weaker enforcement** and **regulatory inconsistencies** compared to New Zealand.

Detailed Concern:

- Transferring customer data to a jurisdiction with different **legal standards**.
- Potential for **data misuse** or **breaches** due to less stringent regulations.
- Our ethical duty: **Protect customer data to the highest standard** regardless of location.

Ethical Concern 1: Appropriate Response

Comprehensive Due Diligence:

- Evaluate cloud providers for compliance with **ISO/IEC 27001** (Information Security) and **ISO/IEC 27701** (Privacy Information).
- Investigate provider's history of compliance with **data protection regulations** and any **data breaches**.

Contractual Safeguards:

- Require provider adherence to **New Zealand's Privacy Act**.
- Establish clear obligations for data handling, **breach notification**, and cooperation with **audits**.

Ethical Concern 2: Consent and Transparency

Customer Awareness:

- Customers are **currently unaware** of plans to offshore data storage to the Philippines.
- Raises concerns about **consent** and **transparency**.

Detailed Concern:

- Ethical obligation to respect customers' **autonomy** and their right to make **informed decisions** about their personal information.
- Failure to inform customers about changes in **data storage location** violates transparency principles, which can lead to **loss of trust** and **legal repercussions** under NZ's Privacy Act.

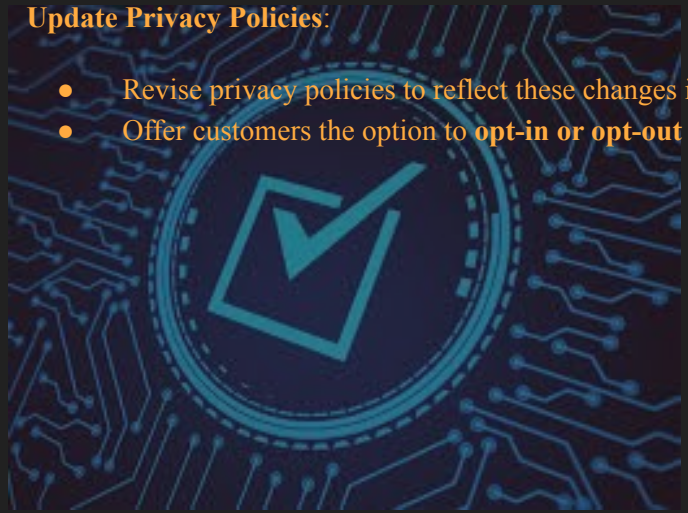
Ethical Concern 2: Appropriate Response

Obtain Informed Consent:

- **Proactive communication** with customers via email, website updates, and customer service announcements.
- Clearly explain the **benefits** of offshoring, why it's being done, and the **protective measures** in place.

Update Privacy Policies:

- Revise privacy policies to reflect these changes in a **clear, understandable language**.
- Offer customers the option to **opt-in or opt-out** of the changes.



Ethical Concern 3: Data Security Risks

Philippines' Data Breach History:

- **Comelec Data Leak (2016)**:
  - Hackers exposed sensitive information of **55 million voters**, including **fingerprints** and **passport data**.
- **Passport Data Exposure (2020)**:
  - Data of **28 million passport holders** at risk due to weak cybersecurity measures.

Detailed Concern:

- **Weak cybersecurity** infrastructure raises concerns about our ability to **safeguard customer data**.
- Ethical responsibility to prevent **foreseeable harm** to our customers by securing their information from unauthorized access, theft, or misuse.

Ethical Concern 3: Appropriate Response

Conduct Regular Security Audits:

- Schedule independent third-party **security assessments** and **penetration tests**.
- Ensure cloud providers follow **cybersecurity best practices** and regularly update defenses against emerging threats.

Develop Incident Response Plans:

- Clear protocols for responding to **data breaches**.
- **Immediate notification** of affected customers and authorities in case of a breach.

To Conclude

References:

Neeraj:

- Privacy Act 2020 No 31 (as at 01 July 2024), Public Act Contents – New Zealand Legislation
- Republic Act 10173 - Data Privacy Act of 2012

Ricky:

- 5 Biggest Data Breaches in the Philippines
- Philippine electoral records breached in 'largest ever' government hack
- Another data breach in Philippines govt dept; ministry concerned over incident and high risk at passport printer
- Data from 28 million passports at risk —DFA exec

Louis:

- Te Mana Raraunga
- PDPA - relevant sections - 12, 16-18, 21, 22
- PDPA implementation - relevant sections - 38
- NZ Privacy Act

Harry:

- New Zealand Information Security Manual (NZISM)
- GDPR - relevant articles: 5, 32, 45
- The NIST Cybersecurity Framework (CSF) 2.0
- ISO/IEC 27001:2022 - Information security management systems
- What Are ISO 27001, ISO 27017, and ISO 27018 Standards?